VCISO SERVICES, LLC

Harlan Ridge Credit Union

Security assessment of member onboarding and account servicing

PREPARED BY

vCISO Services, LLC

ENGAGEMENT

February to April

ASSESSED SERVICE

Six branches, the online banking front end, and the identity and card vendors

DISTRIBUTION

Board, CEO, VP Operations, and Keystone Financial Systems on request

Harlan Ridge runs more security than it can prove, and proof is what will be asked for. The branch estate is the seam running through every major finding.

The annual examination is approaching, and Keystone Financial Systems, the core banking vendor, has asked for evidence of security practice as a condition of contract renewal.

THREE DECISIONS NOW SIT WITH THE BOARD

01

Fund the branch gap

The credit union runs six branches, and every major finding runs through them: an internet-facing appliance carrying an exploited flaw, shared teller logins, networks never scanned, and thirty day log retention.

02

Assign the unowned assets

This engagement built the first asset inventory the service has ever had. It found 22 assets, seven with no named owner, so nobody is answerable for patching them or retiring them.

03

Decide what to tell Keystone

Six of nine prior claims cannot be evidenced. Requalifying them is a choice the board makes before the question arrives.

This report stops at assessment. What to do about each of the risks that follow is a decision for management, not a recommendation from us.

The consolidated risk picture

Seventeen findings consolidate to eleven risks. These eight carry the decisions.

	RISK	LIKELIHOOD	IMPACT	FINDINGS
1	The branch VPN appliance carries an actively exploited flaw	High	Severe	F-09
2	Systems exist that nobody owns, including a live retired login page	Medium	Severe	F-01, F-04
3	Identity control ends at the branch door	High	Major	F-13, F-14
4	The branches have never been scanned	Medium	Major	F-08
5	Detection exists that nobody consumes	Medium	Major	F-06, F-15
6	Six of nine compliance claims cannot be proven	High	Major	F-16
7	Records cannot say what runs, who owns it, or where member data sits	High	Major	F-02, F-03
8	Member emails and a stale credential sit with an unassessed agency	Medium	Moderate	F-05, F-07

Severity, used on pages 04, 06 and 08, rates the technical finding. Likelihood and impact here rate the business consequence. The bottom three change no board decision.

Risks 9 to 11 stay in the workbook: branch log retention at 30 days, the teller check-scanner runtime, and the surrendered patch window. The last two also appear among the technical priorities on page 06. F-12, the core banking version, is a documented accepted risk and is not ranked.

Readiness for the evidence test

The evidence test is one question: can the record be handed over today, dated, with a name on it?

3 of 9

CLAIMS TO KEYSTONE, EVIDENCED TODAY

6

CLAIMS TO WITHDRAW OR REQUALIFY

3

CLOSABLE BY RECORDING WHAT ALREADY HAPPENS

WHAT IT CAN PROVE

- Onboarding identity verification
- The annual policy review
- The quarterly head office scan

WHAT IT CANNOT DEFEND

- Shared teller logins at four of six branches, so no transaction ties to a person
- Access recertification quarterly at head office and never at any branch
- Six prior claims that cannot be evidenced as written

> Three of the six that cannot be evidenced close by documenting practices that already occur: the leaver records, the training register, the disaster recovery report.
>
> The nine claims are set out in full on page 05. Most of the rest turns on money, authority or vendors.

Two deadlines drive this: the approaching annual examination, and Keystone asking for evidence of security practice as a condition of contract renewal.

Head office runs the controls the policy claims. The branches do not, and most of the workforce is at a branch.

CONTROL	HEAD OFFICE	THE BRANCHES
Individual teller logins F-13 · High	Enforced for every user, with a second authentication factor beyond the password.	2 of 6 branches. The other four share one login per station, on a password rotation each branch runs itself.
Access recertification F-14 · Medium	Quarterly. Reviewed, signed and filed. Four quarters on record.	Never. No branch review has ever been performed.

4 of 6

BRANCHES ON SHARED TELLER LOGINS

0

BRANCH ACCESS REVIEWS EVER PERFORMED

Policy section 4.2 requires individual accountability for every transaction. A shared login cannot carry a second factor, so the head office authentication rules do not reach the branch floor. When something goes wrong at a teller window, the credit union cannot say who was at the keyboard.

Claims versus evidence

The nine claims in full. Three stand as written, three partly, three not at all.

THE NINE CLAIMS MADE TO KEYSTONE, ELEVEN MONTHS AGO

PROVEN	Identity verification at member onboarding is performed and recorded
PROVEN	The information security policy is maintained and reviewed annually
PROVEN	Vulnerability scanning is performed quarterly, head office only
PARTLY	Security training is delivered annually, sheets for two of three years
PARTLY	Access reviews are performed quarterly, head office only
PARTLY	Logs are retained twelve months, thirty days at the branches
NO RECORD	Departing staff lose access the same day
NO RECORD	Disaster recovery is tested
NO RECORD	Due diligence is performed on suppliers

THE THREE THAT SURVIVED THE EVIDENCE TEST

Onboarding identity verification
Complete records, generated automatically, for every new member

Annual policy review
Minutes and a signed sign-off page

Quarterly head office scan
Dated reports going back years

Three stand as written. Three are partly true, two at head office only and one for two years of three. Three have no record at all.

Nobody lied.
The six that do not stand cluster where no system writes the record automatically.

A claim scored as supported only when the artifact showing it operating, on a date, done by someone, could be handed over today. Claim wording reconstructed from F-16.

Ranked technical priorities

One item is urgent, two are open with no remediation date, one needs no action.

	ISSUE	WHY IT SITS HERE	SEVERITY
1	Branch VPN concentrator running firmware two releases behind, last updated two years ago	One flaw in that version is on the public catalog of vulnerabilities confirmed as actively exploited. Reachable from the internet, and the door to all six branches.	High
2	Teller check-scanning software that runs only inside an out-of-support browser runtime	All six branches. The vendor's current version removes the dependency. The credit union is two versions behind on a product it pays maintenance for.	Medium
3	Two head office document workflow servers three months behind on updates	The monthly reboot window has been surrendered to month-end three times running. The team raised it and has no authority to take the window back.	Medium
	Core banking server one version behind the newest operating system build	Keystone certifies specific builds and the credit union correctly runs the certified one, with compensating controls recorded in the IT register.	Accepted

> The core banking version is not a gap. It is the vendor's documented requirement, correctly followed.
>
> The scan flags it anyway. It is on this page so that nobody chases it.

Ranked by what each would cost the business, not by the scanner's own scoring. All four come out of the head office vulnerability scan set out on page 07. The board-level ranking is on page 02.

What the scan shows

31 rows resolve to six distinct issues. Six branches have never been in scope.

0 of 6

BRANCHES EVER SCANNED

31

SCAN ROWS RETURNED, HEAD OFFICE ONLY

6

DISTINCT ISSUES ONCE GROUPED



9 of the 31 rows

The check-scanning software issue, printed once per machine.

HOW THE SIX RESOLVE

- 4 material issues, set out on page 06
- 2 housekeeping items on the print infrastructure, recorded in the workbook

> **The six branches have never been scanned.**
> The number of issues there is not low. It is unknown, and those are different things.

The head office scan runs quarterly and runs on schedule. The most recent completed three weeks before this assessment.

What the internet sees

The banking front end grades well from outside. What grew up around it does not.

WHAT IS EXPOSED	WHAT WE OBSERVED FROM OUTSIDE	SEVERITY
`ib-test.harlanridgecu.org`	A live login page for an internet banking product whose vendor contract ended in 2022. Nobody can say which machine serves it or who pays for it. Missing from the asset inventory this engagement built, so it has never been in the quarterly scan.	High
`harlanridgecu.org` `the public marketing site`	The site holds no account data. Grade D on the browser security header check. One legacy path does not redirect to the encrypted site. Its newsletter form sends member email addresses to a mailing service nobody here has assessed.	Medium
`Mail sent in the credit union's name`	Both standard records are published. The enforcing one has been set to take no action for 19 months, and the reports it generates go to a mailbox nobody reads. Members act on emails that appear to come from Harlan Ridge, so this is rated medium rather than low.	Medium

> The online banking front end, run by the digital banking vendor, scores A on both public grades.
>
> Of everything visible from outside, member-facing banking is the best configured. It was not tested.

Observed from outside using public sources only. No traffic was directed at any credit union system.

FRAMEWORK POSITION

The profile heatmap

Identify and Detect are the widest gaps. Detect and Respond compound.

FUNCTION	CURRENT	TARGET	GAP	STATUS	THE DISTANCE, IN ONE LINE
Govern	2	3	+1	ONE STEP SHORT	Policy is real; ownership of assets and alerts is not
Identify	1	3	+2	TWO STEPS SHORT	The inventory produced by this engagement is the first one
Protect	3	3	0	AT TARGET	Met at head office; the branch gap is scored under Govern
Detect	1	3	+2	TWO STEPS SHORT	Alerts unowned, branches unscanned, reports unread
Respond	1	2	+1	ONE STEP SHORT	No documented procedure for anything Detect might find
Recover	2	2	0	AT TARGET	Backups run and restores are tested; the 2023 test went unwritten

COMPOUNDING PAIR

Detect and Respond compound.

The credit union is under-equipped to notice trouble, and has nothing written for the trouble it notices.

Scored 0 to 4 against the six functions of NIST CSF 2.0. Targets are set by inherent risk, assessed as elevated because the credit union moves money, holds identity documents for 51,000 members, operates six locations plus internet-facing channels, and faces a scheduled annual examination. The target is deliberately not the maximum anywhere.

Engagement scope

The boundary every finding in this deck sits inside, and what was deliberately left out.

IN SCOPE

- Branch and online identity verification
- Core banking account creation
- Member web and mobile channels
- Six branch locations
- Identity verification and card issuance vendors

NOT IN SCOPE

- Lending and underwriting
- The ATM estate
- Payments and settlement
- Corporate IT

Scheduled separately. Where one of these touched the assessed service it was recorded and flagged, not assessed.

22 assets identified. 7 have no recorded owner. 4 appear on no internal record.

No asset inventory for this service existed in any form before this engagement.

Among them, one system recorded as decommissioned in 2023 that is still on an active storage contract, invoiced monthly through the current year. Nobody could confirm whether it still holds member identity documents. It sits inside risk 7 on page 02.